

PLAN ESTRATÉGICO DE SEGURIDAD DE LA INFORMACIÓN (PESI)

PESI 2025 – 2030

BANCO LUNA LLENA

Nombre del equipo: CACTUCITOS

Integrantes:

- Josue Nisthaus
- Carlos Caba
- Luciana Velasco
- Daniela Guzman
- Jose Manzaneda

LA PAZ, BOLIVIA - 2026

ADVERTENCIA
Este documento y su contenido se clasifica como USO INTERNO, contiene información propia del Banco Luna Llena, siendo de uso exclusivo del personal autorizado de la institución. No puede ser distribuida ni divulgada a personas ajenas a la misma sin autorización de la Máxima Autoridad Ejecutiva, en forma total o parcial; la reproducción o divulgación NO autorizada de este material estará sujeta a sanciones que correspondan de acuerdo con la legislación vigente y a las políticas y normas del Banco Luna Llena.

Versión: 2.0

Fecha: 13/04/2026

Aprobado por: Gerente General del Banco Luna Llena

Fecha de vigencia: 13/04/2026

Histórico de revisiones del Documento

Versión	Fecha	Detalle de Revisión y Cambios
1.0	11/03/2026	Creación del documento
2.0	13/04/2026	Modificación de formato

Indice

1. Introducción	3
2. Criterios de Seguridad de la Información	3
2.1 Criterios Principales	3
2.2 Criterios Secundarios	3
3. Diagnóstico de Seguridad Actual	4
4. Objetivos Estratégicos de Seguridad	5
5. Iniciativas de Seguridad	5
6. KPIs de Seguridad de la Información	5
7. Horizonte del Plan	6

1. Introducción

El Plan Estratégico de Seguridad de la Información (PESI) del Banco Luna Llena establece el marco de gestión de la seguridad de la información para el período 2025–2030, alineado con el estándar internacional ISO/IEC 27001 y con los objetivos del PEI institucional. Este plan es responsabilidad del Gerente de Seguridad de la Información, quien forma parte del nivel directivo del área de TI y trabaja de forma coordinada con las tres subgerencias operativas y el Analista de Calidad.

El PESI define los criterios de seguridad, los controles requeridos, las iniciativas de mejora y los indicadores de desempeño que garantizan la protección de los activos de información del banco y de sus clientes.

2. Criterios de Seguridad de la Información

2.1 Criterios Principales

- **Confidencialidad:** La información solo debe ser accesible para personas autorizadas. Se aplican controles de acceso basados en roles (RBAC) y cifrado de datos en tránsito y en reposo.
- **Integridad:** La información debe mantenerse exacta, completa y sin alteraciones no autorizadas. Se implementan controles de integridad mediante hash y firmas digitales.
- **Disponibilidad:** Los sistemas y la información deben estar accesibles cuando los usuarios autorizados los requieran. El SLA mínimo de disponibilidad para sistemas críticos es del 99.9%.

2.2 Criterios Secundarios

- **Autenticación:** Verificación de identidad mediante autenticación multifactor (MFA) para todos los accesos a sistemas críticos.
- **Cumplimiento:** Adherencia a regulaciones y estándares aplicables: ISO/IEC 27001, PCI DSS v4.0 y normativas del regulador financiero nacional. La aplicación de cada estándar se describe a continuación:

ISO/IEC 27001: Se aplicará mediante el diseño e implementación de un Sistema de Gestión de Seguridad de la Información (SGSI) formal, que incluye la definición del alcance, el análisis y tratamiento de riesgos (metodología ISO 31000), la selección de controles del Anexo A, y la ejecución de auditorías internas y revisiones por la dirección. El proceso culminará con la certificación por un organismo acreditado antes de 2027, y la mejora continua se garantizará mediante ciclos PDCA anuales.

PCI DSS v4.0: Se aplicará sobre el entorno de datos de titulares de tarjetas (CHD) mediante la segmentación de red con VLANs dedicadas, el cifrado TLS 1.3 para datos en tránsito, la tokenización de datos sensibles en reposo, el control de acceso mínimo necesario (least privilege) y el escaneo trimestral de vulnerabilidades. El cumplimiento será verificado anualmente por un Qualified Security Assessor (QSA) externo.

Normativas del regulador financiero nacional: Se aplicarán mediante la revisión continua de las circulares y resoluciones emitidas por la ASFI (Autoridad de Supervisión del Sistema Financiero), asegurando que las políticas internas de seguridad, los procedimientos de gestión de incidentes y los controles de acceso estén alineados con los requisitos regulatorios vigentes. Se designará un responsable de cumplimiento normativo que reportará trimestralmente al Gerente de Seguridad de la Información.

- **Confiabilidad:** Los sistemas deben operar de forma predecible y confiable, con registros de auditoría (logs) disponibles para trazabilidad.
- **No repudio:** Las operaciones y transacciones deben quedar registradas de forma que ninguna parte pueda negar su realización, mediante firmas digitales y registros auditables.

3. Diagnóstico de Seguridad Actual

Dominio ISO 27001	Situación Actual	Nivel (1-5)	Prioridad
Control de Acceso	Contraseñas simples, sin MFA en todos los sistemas	2	ALTA
Gestión de Incidentes	Procedimientos básicos, sin SIEM activo	2	ALTA
Seguridad en Redes	Firewall activo, sin segmentación completa por VLAN	3	MEDIA
Continuidad del Negocio	BCP documentado, sin pruebas regulares	2	ALTA
Gestión de Activos	Inventario parcial de activos de información	2	MEDIA
Cumplimiento y Auditoría	Sin auditorías internas formales de seguridad	1	ALTA

4. Objetivos Estratégicos de Seguridad

N°	Objetivo de Seguridad	Iniciativa Clave	Meta al 2030
OS 1	Implementar un SGSI certificado en ISO 27001	Diseño, implementación y certificación del SGSI	Certificación ISO 27001 al 2027
OS 2	Garantizar el cumplimiento de PCI DSS v4.0	Segmentación de red CHD, cifrado TLS 1.3	Auditoría QSA aprobada anualmente
OS 3	Fortalecer la gestión de identidades y accesos	Implementación de MFA y solución IAM centralizada	MFA al 100% de usuarios críticos al 2026
OS 4	Establecer un centro de operaciones de seguridad	Implementación de SIEM y SOC funcional	SOC operativo con monitoreo 24/7 al 2027
OS 5	Asegurar la continuidad ante incidentes críticos	Plan de respuesta a incidentes y pruebas de DR	RTO ≤ 4h y RPO ≤ 2h para sistemas críticos

5. Iniciativas de Seguridad

Iniciativa	Año Inicio	Año Fin	Responsable	OS Asociado
Diseño e implementación del SGSI (ISO 27001)	2025	2027	GSI	OS1
Implementación de MFA para todos los sistemas	2025	2026	GSI / Sub. Redes	OS3
Segmentación de red y zonas de seguridad (VLAN)	2025	2026	Sub. Redes	OS2, OS1
Implementación de SIEM y SOC 24/7	2026	2027	GSI	OS4
Capacitación en ciberseguridad para todo el personal	2025	2030	GSI / RRHH	OS1, OS3
Pruebas de penetración y ethical hacking	2025	2030	GSI	OS1, OS2
Plan de Respuesta a Incidentes y pruebas de DR	2025	2026	GSI / Sub. Ops	OS5

6. KPIs de Seguridad de la Información

Indicador	Línea Base	Meta 2030	Frecuencia
Incidentes de seguridad críticos	3 por año	0 por año	Mensual
Usuarios con MFA activo	20%	100%	Trimestral
Tiempo de detección de incidentes (MTTD)	72 horas	< 1 hora	Mensual
Tiempo de respuesta ante incidentes (MTTR)	48 horas	< 4 horas	Mensual
Cumplimiento PCI DSS	75%	100%	Anual (QSA)
Personal capacitado en ciberseguridad	40%	95%	Anual
Nivel de madurez SGSI (ISO 27001)	No certificado	Certificado	Anual

7. Horizonte del Plan

El PESI tiene un horizonte de 5 años (2025–2030), alineado con el PEI y el PETI. Las fases de implementación son: Fase 1 – Protección Base (2025–2026): MFA, segmentación de red, plan de respuesta a incidentes y capacitación inicial. Fase 2 – Madurez (2026–2028): SGSI completo, SIEM y SOC operativo, y certificación ISO 27001. Fase 3 – Optimización (2028–2030): mejora continua del SGSI, auditorías regulares y cumplimiento sostenido de PCI DSS.